

Section 06

Industrial Security (Bachelor)



Section 06 – Vulnerabilities and Assessment

Vulnerabilities and Assessment

Lecture Notes

Department of Computer Science

2026-05-17

Industrial Security (Bachelor)

Section 06

Industrial Security (Bachelor)



Section 06 – Vulnerabilities and Assessment

Vulnerabilities and Assessment
Lecture Notes
Department of Computer Science

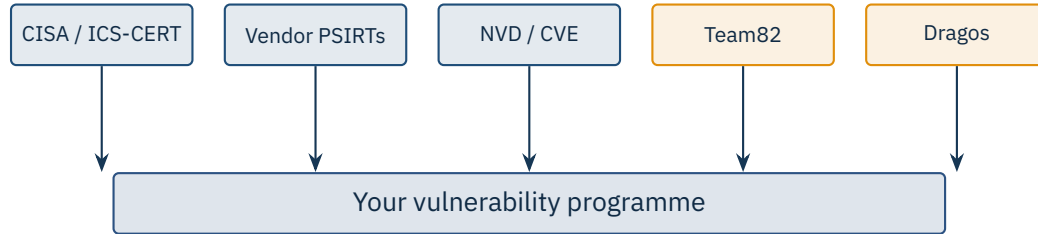
- 1 Vulnerability Intelligence
- 2 Asset Inventory and Scanning
- 3 Vulnerability Management Workflow

By the end of this section you will be able to

- Find and interpret ICS vulnerability advisories.
- Apply CVSS v3.1 with environmental modifiers in an OT context.
- Plan a safe asset inventory across passive and active methods.
- Run a vulnerability management workflow that fits OT constraints.

1

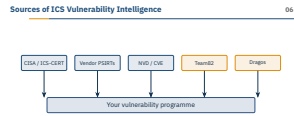
Vulnerability Intelligence



2026-05-17

Industrial Security (Bachelor)
└ Vulnerability Intelligence

└ Sources of ICS Vulnerability Intelligence



Walk the room through the feed landscape: CISA ICSA advisories are the single most useful free feed, but they trail the vendor PSIRTs by weeks. Stress that nobody can rely on one source — Team82 (Claroty), Dragos, Nozomi Labs, and Forescout Vedere Labs all surface bugs that never make it into NVD on the day of disclosure. Make the point that a vulnerability programme is a *pipeline*, not a website you visit when you remember. Ask students which of these feeds they think publishes the most ICS-specific content per year, then reveal that CISA and the vendor PSIRTs together dwarf NVD for OT relevance.

ICSA-25-XXX-NN ACME Controller series X / firmware 2.0–2.4

CVSS v3.1: 9.8 / AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CWE-798: Use of hard-coded credentials

Impact: Unauthenticated remote attacker may take control of the device

Mitigation: Upgrade to FW 2.5; segregate behind firewall; disable web UI

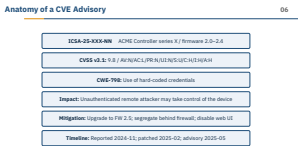
Timeline: Reported 2024-11; patched 2025-02; advisory 2025-05

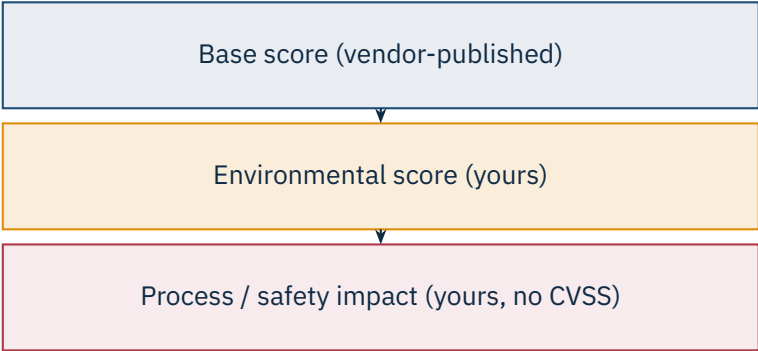
2026-05-17

Industrial Security (Bachelor)
└─ Vulnerability Intelligence

└─ Anatomy of a CVE Advisory

Walk the advisory top-to-bottom and explain each field — the ICSA-ID encodes year and day-of-year, the affected firmware band is what the asset inventory must match against, and the CVSS vector is more informative than the headline score. Highlight the six-month gap between report and advisory — that is normal in OT and explains why threat intel beats public feeds. Note that CWE-798 (hard-coded credentials) is the single most common root cause across PLCs in the last decade. Ask the TA to have students open a real CISA advisory on the lab laptops and read the same fields aloud — it makes the structure stick.





Base alone is misleading. “Low Availability” in IT may equal *plant shutdown* in OT. Always combine with process consequence.

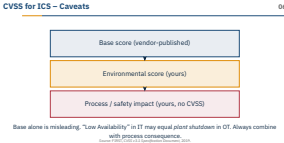
Source: FIRST, CVSS v3.1 Specification Document, 2019.

2026-05-17

Industrial Security (Bachelor)
└─ Vulnerability Intelligence

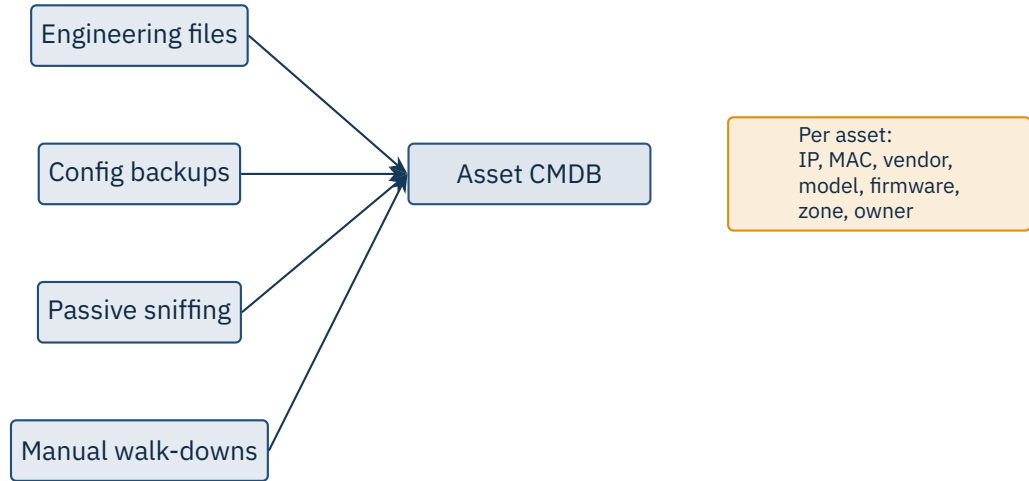
└─ CVSS for ICS – Caveats

Show CVSS in its honest light: a base score of 9.8 on a PLC behind a one-way data diode is a different risk from the same 9.8 on a perimeter HMI. CISA started publishing environmental guidance for ICS because of exactly this issue. Pre-empt the IT mindset that a high CVSS means immediate patching — in OT, patching is a project, not a sprint. The third row is the one CVSS does not capture at all: a low-availability bug that drops a safety interlock is plant-stop territory, not a ticket. Ask the room: if a vendor releases a critical patch but the next maintenance window is in six months, what compensating controls would they propose?



2

Asset Inventory and Scanning

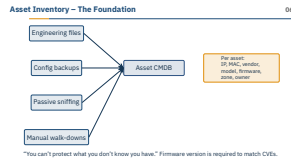


“You can’t protect what you don’t know you have.” Firmware version is required to match CVEs.

2026-05-17

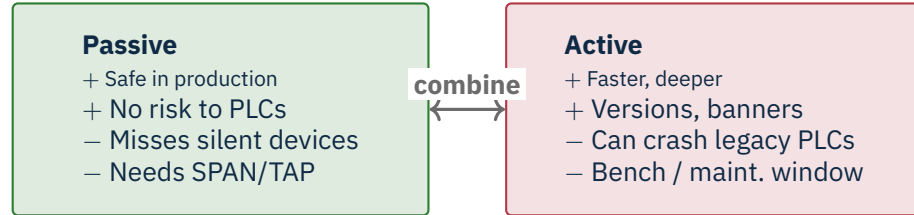
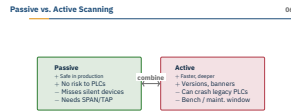
Industrial Security (Bachelor)
└─ Asset Inventory and Scanning

└─ Asset Inventory – The Foundation



Drive home that everything downstream – CVE matching, segmentation, incident response – collapses without an accurate inventory. The dirty secret is that most plants discover 20–40% more devices the first time they deploy a passive tool like Claroty CTD, Nozomi Guardian, or Microsoft Defender for IoT. Stress the four-input model on the slide: engineering files for what *should* be there, config backups for ground truth, passive sniffing for what is actually talking, and walk-downs for the analogue gear that never appears on the wire. Firmware version is the load-bearing field – without it you cannot answer “are we affected?” for any advisory. War story to share: a plant we visited had three undocumented Modbus gateways feeding a historian; passive scan found them in an afternoon.

2026-05-17



Demolish the myth that “passive is always safe” — it is mostly safe, but a misconfigured SPAN port can cause switch CPU spikes, and some passive tools do send the occasional active probe (read the manual). Tell the war story: a junior consultant ran an `nmap -sS` sweep against a live cement plant and bricked two 1990s-vintage PLCs that crashed on any unexpected TCP flag combination — four-hour outage, vendor flew in, the consultant did not come back. The lesson is not “never scan” but “never scan production without a documented bench result for that exact model.” Tools like Tenable.ot, Forescout, and Armis advertise “safe active” modes but they still require vendor sign-off in regulated plants. Bridge to the next slide: even on a bench, you tune nmap to crawl, not sprint.



```
1 # Bench only -- never on production
2 nmap -sT -p 102,502,20000,44818,20256 \
3   --max-rate 5 --scan-delay 200ms \
4   -Pn 192.168.10.10
5
6 nmap -p 102 --script s7-info 192.168.10.10
7 nmap -p 502 --script modbus-discover 192.168.10.10
```

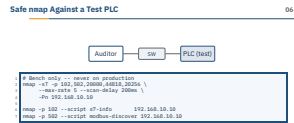
2026-05-17

Industrial Security (Bachelor)

Asset Inventory and Scanning

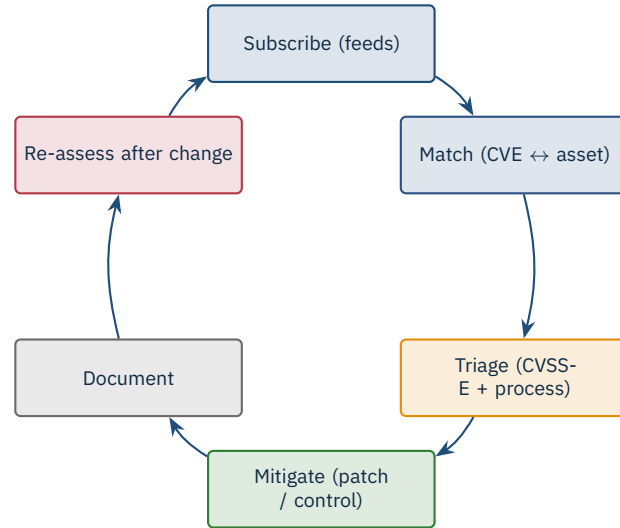
Safe nmap Against a Test PLC

Explain every flag: -sT avoids the half-open SYN scan that some legacy stacks mis-handle, -max-rate 5 keeps the device from drowning, -scan-delay 200ms gives slow CPUs time to breathe, and -Pn skips the ICMP ping because many PLCs reply oddly. The port list covers the usual ICS suspects: 102 Siemens S7, 502 Modbus/TCP, 20000 DNP3, 44818 EtherNet/IP, 20256 PCWorx. Hammer home the comment on line one – “bench only.” Even with these settings, the Nmap NSE scripts (s7-info, modbus-discover) send protocol-specific queries that can confuse some firmware versions. If a student asks “can I try this at my internship?”, the answer is “not without written approval and a tested rollback.”



3

Vulnerability Management Workflow

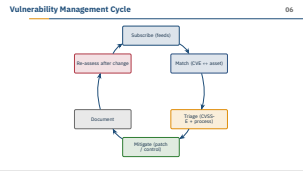


2026-05-17

Industrial Security (Bachelor)

└─ Vulnerability Management Workflow

└─ Vulnerability Management Cycle



Treat this as the spine of the rest of the lecture: every later concept (advisories, scanning, patching) plugs into one of the six wedges. The two wedges students under-estimate are *Document* and *Re-assess after change* — both are where audits live or die. The triage wedge is where CVSS environmental modifiers actually get applied; pair it back to the earlier slide. Mention that NIST SP 800-82 Rev. 3 (2023) formalises this loop and explicitly tells you not to skip re-assessment after a firmware update. Ask the room: which wedge do they think breaks first in a small plant with no dedicated security staff? — the usual answer is *match*, because nobody keeps the asset inventory current.

Coordinated disclosure

Bug bounty

Silent fix

Why ICS lags

Vendor patch cycles average **90–180 days**; many critical CVEs are released without code. Always check the security advisory page weekly, not the homepage.

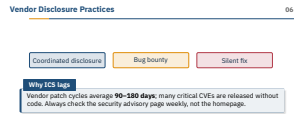
2026-05-17

Industrial Security (Bachelor)

└ Vulnerability Management Workflow

└ Vendor Disclosure Practices

Coordinated disclosure is the gold standard: researcher reports privately, vendor patches, advisory drops together — this is how Siemens ProductCERT and Rockwell PSIRT operate. Bug bounties are still rare in OT but Schneider Electric and ABB have programmes worth knowing about. The ugly category is silent fix — a vendor patches a bug in a firmware changelog entry that reads “stability improvements”; this happens more than the industry admits. War story: a major drive vendor took 18 months between researcher report and shipping firmware for a critical RCE, because every customer in three regulated industries needed to schedule a maintenance window. Tell students to bookmark the security advisory subpages of the vendors they actually use, and to set RSS or email alerts — the homepage will never tell them.



- **CWE-798** – hard-coded credentials in firmware
- **CWE-22** – path traversal in web UIs
- **CWE-787** – out-of-bounds write in protocol parsers
- **CWE-306** – missing authentication on critical functions
- **CWE-352** – CSRF in HMI web interfaces
- **CWE-918** – SSRF in cloud connectors

Pattern recognition

Once you have read 50 ICS advisories you will start to recognise the same weaknesses across vendors.

Source: MITRE, *Common Weakness Enumeration (CWE)*, <https://cwe.mitre.org>.

2026-05-17

Industrial Security (Bachelor)

└ Vulnerability Management Workflow

└ Common ICS Weakness Patterns

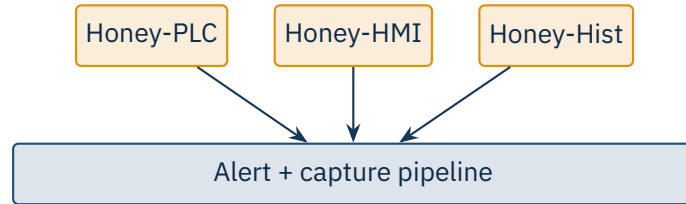
These six CWEs cover the majority of ICS advisories from the last five years — Claroty's Team82 half-yearly reports back this up. Hard-coded credentials (CWE-798) are the embarrassment that keeps repeating because of debug accounts left in shipping firmware. The protocol-parser bugs (CWE-787) are the dangerous ones — a single malformed Modbus or EtherNet/IP packet crashing the stack means anyone on the cell network can DoS a controller. Push back on the “we have antivirus” reflex: antivirus on the engineering workstation does nothing for a buffer overflow in the PLC's TCP stack itself, because the PLC has no agent and no patch until the vendor ships firmware. Encourage students to read raw advisories in the lab — pattern recognition is the only way to triage 50 new CVEs a week.

Common ICS Weakness Patterns

- **CWE-798** – hard-coded credentials in firmware
- **CWE-22** – path traversal in web UIs
- **CWE-787** – out-of-bounds write in protocol parsers
- **CWE-306** – missing authentication on critical functions
- **CWE-352** – CSRF in HMI web interfaces
- **CWE-918** – SSRF in cloud connectors

Pattern recognition
Once you have read 50 ICS advisories you will start to recognise the same weaknesses across vendors.

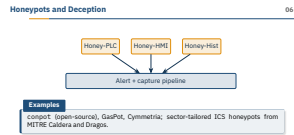
Source: MITRE, Common Weakness Enumeration (CWE), <https://cwe.mitre.org>



Examples

conpot (open-source), GasPot, Cymmetria; sector-tailored ICS honeypots from MITRE Caldera and Dragos.

2026-05-17



Honeypots in OT are useful as an *intelligence* tool, not a defence: any traffic hitting a fake Honey-PLC inside the cell network is by definition unwanted and worth alerting on. The catch is realism — conpot fools casual Shodan crawlers but not a targeted attacker who tries to read a real-looking ladder programme. Stress the alert pipeline at the bottom of the diagram: without immediate routing into the SOC, a honeypot is just a logfile nobody reads. Real-world note: a sector-CERT in Europe runs a federated honeypot grid that has caught early stages of ransomware-affiliate scanning weeks before any victim went public. Briefly mention deception platforms like Acalvio and Illusive that go beyond a single fake host.



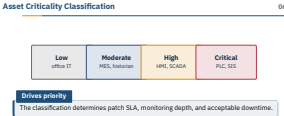
Drives priority

The classification determines patch SLA, monitoring depth, and acceptable downtime.

2026-05-17

- Industrial Security (Bachelor)
 - Vulnerability Management Workflow
 - Asset Criticality Classification

Classification is the lever that turns an asset inventory into a risk-managed programme — without it, every CVE looks equally urgent and the team burns out. Walk through the four tiers and note that SIS (safety instrumented systems) live in their own world: any change requires functional-safety re-validation under IEC 61511, often months of work. Stress that the boundary between High and Critical is where most plant arguments happen — operators want to call everything critical, security wants tighter scope. The classification also feeds the patch cadence table on the next slide: critical assets get the longest lead time, not the shortest, because the safety re-validation cost dominates. Encourage TAs to ask students which tier they would put a wireless field gateway in — the answer depends entirely on what it controls.



2026-05-17

Industrial Security (Bachelor)
└ Vulnerability Management Workflow

└ Patching Cadence – IT vs OT

Patching Cadence – IT vs OT		
	IT	OT
Critical CVE	48–72 hours	30–90 days, with vendor approval
Normal patch	Monthly Patch Tuesday	Annual maintenance window
Reboot tolerance	Routine	Co-ordinated, with operators
Rollback plan	Standard	Mandatory + tested
Compensating controls When you cannot patch quickly, deploy a virtual patch (IPS rule) or tighten the firewall around the affected service.		

	IT	OT
Critical CVE	48–72 hours	30–90 days, with vendor approval
Normal patch	Monthly Patch Tuesday	Annual maintenance window
Reboot tolerance	Routine	Co-ordinated, with operators
Rollback plan	Standard	Mandatory + tested

Compensating controls

When you cannot patch quickly, deploy a virtual patch (IPS rule) or tighten the firewall around the affected service.

The right-hand column is the single biggest culture shock for students coming from IT. Patch Tuesday does not exist in OT — a “critical” patch may take 30 to 90 days simply because the vendor requires regression testing on the customer’s exact firmware band before authorising deployment. The mandatory rollback row is not optional: if a patched controller refuses to come back up, a half-staffed Sunday night shift cannot improvise. War story to land: a refinery sat on a critical EtherNet/IP CVE for 18 months because the annual turnaround was the only opportunity to take the affected cell offline — they bridged the gap with a Tofino IPS rule that dropped the malformed packet upstream. That virtual patch was the only thing standing between them and CVE exposure for a year and a half.

★ Key Takeaway: What to remember from this section

- Track CVEs from CISA, vendor PSIRTs, and threat intel feeds.
- Asset inventory with firmware versions is the foundation.
- CVSS base alone misleads – always add environmental and process impact.
- Active scans only on test benches; passive sniffing is the production-safe default.

2026-05-17

Industrial Security (Bachelor)

└ Vulnerability Management Workflow

└ Summary – Section 06

Recap the four pillars: feeds, inventory, environmental scoring, and scanning hygiene — if students forget everything else, these four keep them from making the worst mistakes. Re-emphasise that the OT vulnerability programme is measured in months and years, not hours and days, and that compensating controls are a first-class deliverable, not a failure mode. Tease the next section: with vulnerabilities catalogued and prioritised, the natural next question is how attackers chain them into incidents — which is the threat-modelling and attack-path material. Optional closing question for the room: “Name one thing you will do differently when you read your next CVE advisory.” Their answers tell the TA whether the environmental-modifier message landed.

★ Key Takeaway: What to remember from this section

- Track CVEs from CISA, vendor PSIRTs, and threat intel feeds.
- Asset inventory with firmware versions is the foundation.
- CVSS base alone misleads – always add environmental and process impact.
- Active scans only on test benches; passive sniffing is the production-safe default.

- FIRST. *Common Vulnerability Scoring System v3.1 Specification Document*, 2019.
- MITRE. *Common Weakness Enumeration (CWE)*, <https://cwe.mitre.org>.
- CISA. *ICS Advisories archive*, <https://www.cisa.gov/news-events/cybersecurity-advisories/ics-advisories>.
- NIST. *National Vulnerability Database (NVD)*, <https://nvd.nist.gov>.
- Forescout Vedere Labs. ICS vulnerability research (e.g. Ripple20, Urgent/11, Project Memoria).
- Claroty Team82. *ICS Risk & Vulnerability Reports*, half-yearly.
- Dragos. *Year in Review*, annual.
- Stouffer, K. et al. *NIST SP 800-82 Rev. 3*, Sep 2023 (vulnerability management for OT).
- Bytes Lab et al. *CodeSys CoDe16 advisories*, 2023.
- INL. *Recommended Practice: Patch Management for Control Systems*, 2008.

End of Section 06

Vulnerabilities and Assessment

Questions and discussion

